Universidad Nacional · Escuela de Informática
Administración de Bases de Datos · II Ciclo 2026

Controles ISO/IEC 27001:2022 para la confidencialidad en la administración de bases de datos

Diseño, implementación y evaluación de controles en Oracle Database 21c Express Edition

Estudiante: **Gloriana Sojo Pereira**
Profesor: Johnny Villalobos Murillo

Heredia, Costa Rica · Octubre de 2026

Contenido

1. Introducción **3**

1.1 Objetivos . . . 3

2. Marco teórico **4**

2.1 ISO/IEC 27001:2022 frente a la versión 2013 . . . 4

2.2 Mínimo privilegio y separación de funciones . . . 4

2.3 Arquitectura de confianza cero (Zero Trust) . . . 4

2.4 Cifrado de datos en reposo, en tránsito y en respaldos . . . 5

2.5 Enmascaramiento, Data Redaction y Virtual Private Database . . . 5

2.6 Prevención de fuga de datos (DLP) . . . 5

2.7 Registro, auditoría y SIEM . . . 5

2.8 Ley 8968 de Costa Rica . . . 6

3. Metodología **7**

3.1 Riesgos de confidencialidad . . . 7

3.2 Criterio de madurez e indicador RC . . . 7

3.3 Ambiente y procedimiento real . . . 7

4. Descripción del artefacto **8**

5. Resultados **9**

5.1 Evaluaciones simuladas: Tres Patitos . . . 9

5.2 Evaluaciones reales: Laboratorio UNA · XEPDB1 . . . 9

5.3 Pruebas funcionales . . . 10

5.4 Revisión de privilegios . . . 10

6. Problemas encontrados y lecciones aprendidas **11**

7. Pendientes y recomendaciones **11**

8. Conclusiones **11**

9. Uso de inteligencia artificial **12**

Referencias **13**

Anexo A. Archivos de evidencia **13**

1. Introducción

Las bases de datos concentran la información más valiosa y más sensible de una organización: datos personales, salarios, cédulas, información financiera. La confidencialidad de esos datos no depende solo de la tecnología, sino de cómo se administran las cuentas, los privilegios, los respaldos, la auditoría y las conexiones. Por eso este trabajo aborda la confidencialidad desde los *procesos* del administrador de bases de datos (DBA) y no desde una lista aislada de productos.

El proyecto toma como referencia la norma ISO/IEC 27001:2022 y su guía de controles ISO/IEC 27002:2022. A partir de cinco riesgos de confidencialidad (R-CONF-01 a R-CONF-05) se identificaron doce tareas del DBA, se asociaron a controles del Anexo A, se definieron quince controles observables por un auditor externo y se construyó una matriz de evaluación con criterios de madurez de 0 a 4. Todo el trabajo se reúne en un artefacto web interactivo que permite registrar evaluaciones y comparar su resultado en el tiempo.

La evaluación se aplicó de dos formas. Primero, como simulación solicitada por el curso, sobre la empresa ficticia *Tres Patitos*. Después, sobre una instalación real de Oracle Database 21c Express Edition (base XEPDB1), en la que se midió el estado inicial, se implementaron los controles con scripts, se ejecutaron pruebas funcionales y se volvió a medir. El resultado real pasó de un riesgo de confidencialidad controlado (RC) de 8,8 % a 86,6 %.

1.1 Objetivos

Objetivo general. Diseñar, implementar y evaluar controles de ISO/IEC 27001:2022 que protejan la confidencialidad de la información en la administración de una base de datos Oracle.

- Identificar los riesgos de confidencialidad asociados a los procesos del DBA y valorarlos con la fórmula impacto × probabilidad.
- Relacionar cada tarea del DBA con controles del Anexo A, su implementación en Oracle y la evidencia observable.
- Construir una matriz de evaluación y un indicador (RC) que permitan comparar evaluaciones en el tiempo.
- Implementar los controles en Oracle 21c XE y comprobar su funcionamiento con pruebas de verificación y pruebas funcionales.

2. Marco teórico

2.1 ISO/IEC 27001:2022 frente a la versión 2013

ISO/IEC 27001 establece los requisitos de un sistema de gestión de seguridad de la información (SGSI) basado en el análisis de riesgos y en la mejora continua del ciclo Planificar-Hacer-Verificar-Actuar (ISO/IEC, 2022a). La edición 2022 conservó la estructura de cláusulas 4 a 10, pero reorganizó por completo el Anexo A: los 114 controles de 2013, distribuidos en 14 dominios, pasaron a 93 controles agrupados en cuatro temas: organizacionales (37), de personas (8), físicos (14) y tecnológicos (34). La guía ISO/IEC 27002:2022 añadió además atributos a cada control, como el tipo (preventivo, detectivo o correctivo) y la propiedad que protege (confidencialidad, integridad o disponibilidad), lo que facilita filtrar los controles que interesan a un objetivo concreto (ISO/IEC, 2022b).

La edición 2022 incorporó once controles nuevos. Varios son centrales para una base de datos: A8.10, eliminación de información; A8.11, enmascaramiento de datos; A8.12, prevención de fuga de datos; A8.9, gestión de la configuración, y A8.16, actividades de monitoreo. Antes, estas prácticas quedaban implícitas en controles generales; ahora el auditor puede exigirlas de forma explícita. Las organizaciones certificadas con la versión 2013 tuvieron plazo hasta el 31 de octubre de 2025 para migrar a la nueva edición.

2.2 Mínimo privilegio y separación de funciones

El principio de mínimo privilegio establece que cada usuario y cada programa deben operar con el menor conjunto de privilegios necesario para su trabajo (Saltzer y Schroeder, 1975). En Oracle se aplica mediante roles por función en lugar de privilegios directos, evitando el rol DBA y los privilegios ANY en cuentas de uso cotidiano, y revisando periódicamente qué privilegios se usan en realidad con el paquete DBMS_PRIVILEGE_CAPTURE (Oracle, 2021c). La separación de funciones (A5.3) complementa ese principio: quien administra la base no debe ser quien controla su auditoría, porque podría borrar el rastro de sus propias acciones. En Oracle esto se logra con el rol AUDIT_ADMIN asignado a una responsable distinta del DBA operativo.

2.3 Arquitectura de confianza cero (Zero Trust)

El modelo de confianza cero parte de que ninguna conexión es confiable por estar dentro de la red de la organización: cada acceso a un recurso se autentica, se autoriza y se cifra de forma individual, con el menor privilegio posible (Rose et al., 2020). Aplicado a una base de datos, implica autenticación fuerte, cifrado de todas las conexiones, restricción de los equipos que pueden conectarse al *listener* y control de acceso a nivel de fila y de columna, de modo que un usuario autenticado solo vea los datos que su función requiere.

2.4 Cifrado de datos en reposo, en tránsito y en respaldos

Transparent Data Encryption (TDE) cifra los archivos de datos de tablespaces completos o de columnas específicas; las aplicaciones no cambian, pero quien obtenga una copia de los archivos o de un disco descartado no puede leerlos sin la llave maestra guardada en el *keystore* (Oracle, 2021b). Para los datos en tránsito, Oracle ofrece cifrado nativo de red (por ejemplo, AES-256 con verificación de integridad SHA-256), configurado en el archivo sqlnet.ora, y también TLS, el protocolo estándar de cifrado de conexiones, cuya versión vigente es la 1.3 (Rescorla, 2018). Los respaldos son otra copia completa de la base, por lo que deben cifrarse: RMAN permite hacerlo con contraseña o con la llave de TDE y validar después que el respaldo se puede restaurar (Oracle, 2021d).

2.5 Enmascaramiento, Data Redaction y Virtual Private Database

El enmascaramiento de datos (A8.11) oculta total o parcialmente los valores sensibles. Puede ser *estático*, cuando se reemplazan los datos reales al copiar una base a desarrollo o pruebas, o *dinámico*, cuando los datos se ocultan en el momento de la consulta. Oracle Data Redaction implementa el enmascaramiento dinámico: el dato se conserva intacto en la tabla y se muestra, por ejemplo, como un salario en cero o una cédula con solo los últimos dígitos visibles, según la política y el usuario (Oracle, 2021b). Virtual Private Database (VPD) restringe las *filas*: una función de política agrega automáticamente una condición a cada consulta, de modo que un usuario solo ve los registros de su departamento aunque consulte la tabla completa (Oracle, 2021c).

2.6 Prevención de fuga de datos (DLP)

La prevención de fuga de datos (A8.12) busca impedir que la información sensible salga de la organización por canales no autorizados. En una base de datos los canales típicos son las exportaciones masivas (Data Pump), los respaldos sin cifrar y las cuentas con privilegios de lectura global. Los controles correspondientes son restringir los roles de exportación, cifrar respaldos y datos en reposo, y auditar las lecturas de las tablas sensibles para detectar volúmenes anómalos (ISO/IEC, 2022b).

2.7 Registro, auditoría y SIEM

El registro de eventos (A8.15) permite saber quién hizo qué y cuándo. Oracle Unified Auditing centraliza los registros en una sola vista y permite definir políticas sobre acciones específicas, como las consultas a una tabla con datos personales o los inicios de sesión fallidos (Oracle, 2021c). Un registro solo es útil si alguien lo revisa: un SIEM (*Security Information and Event Management*) recolecta los registros de distintos sistemas, los correlaciona y genera alertas, y su gestión debe incluir retención, protección contra modificación y revisión periódica (Kent y Souppaya, 2006).

2.8 Ley 8968 de Costa Rica

La Ley 8968, de Protección de la Persona frente al Tratamiento de sus Datos Personales, garantiza el derecho a la autodeterminación informativa (Asamblea Legislativa de la República de Costa Rica, 2011). Clasifica como datos sensibles, entre otros, los relacionados con la salud, el origen étnico o las convicciones de las personas, y exige al responsable de una base de datos adoptar medidas técnicas y organizativas que garanticen la seguridad de los datos y eviten su alteración, pérdida, tratamiento o acceso no autorizado (art. 10), así como guardar la confidencialidad de la información (art. 11). Su reglamento, el Decreto Ejecutivo 37554-JP, detalla esas medidas, y la Agencia de Protección de Datos de los Habitantes (PRODHAB) supervisa su cumplimiento. Los controles de este trabajo son una forma concreta de demostrar esas medidas de seguridad sobre una base de datos.

3. Metodología

El trabajo siguió el ciclo PHVA de ISO/IEC 27001. En **Planificar** se identificaron los riesgos, las tareas del DBA y los controles; en **Hacer** se implementaron los controles con scripts SQL y procedimientos de servidor; en **Verificar** se ejecutaron pruebas de verificación (PT) y pruebas funcionales (PF), y en **Actuar** se corrigieron los fallos encontrados y se documentaron las decisiones pendientes.

3.1 Riesgos de confidencialidad

Cada riesgo se valoró como impacto × probabilidad, ambos en escala de 1 a 5.

ID	Riesgo	I	P	I×P
R-CONF-01	Exceso de privilegios y privilegios heredados	4	4	16
R-CONF-02	Acceso no autorizado a la instancia	5	3	15
R-CONF-03	Exposición de datos en reposo y en respaldos	5	2	10
R-CONF-04	Datos reales en ambientes de desarrollo y pruebas	4	4	16
R-CONF-05	Accesos indebidos no detectados	4	3	12

Tabla 1. Riesgos de confidencialidad y su valoración.

3.2 Criterio de madurez e indicador RC

Cada control observable se califica de 0 a 4: 0, inexistente; 1, inicial o informal; 2, parcial; 3, implementado y verificado; 4, implementado, verificado y revisado de forma periódica. Los niveles 0 y 1 equivalen a *No cumple*, el 2 a *Parcial* y los niveles 3 y 4 a *Cumple*. Con esos niveles se calcula el riesgo de confidencialidad controlado de una evaluación E(i, b, t) de la empresa *i*, la base *b* y la fecha *t*:

```
RC(i, b, t) = (CS1·W1 + CS2·W2 + … + CS15·W15) / (W1 + W2 + … + W15)
```

CS_k vale 1 si el control cumple, 0,5 si es parcial y 0 si no cumple. W_k es el peso del control: el valor I×P del riesgo más alto que atiende. La suma de los pesos es 216. El resultado se interpreta con un semáforo: rojo de 0 a 30 %, amarillo de 30 a 70 % y verde de 70 a 100 %.

3.3 Ambiente y procedimiento real

Las pruebas reales se hicieron en Oracle Database 21c Express Edition 21.3 sobre Windows, en la base conectable XEPDB1. La verificación la ejecutó una cuenta de solo lectura, AUDITOR_EXT, que representa al auditor externo y consulta las vistas del diccionario de datos (Oracle, 2021a). El orden fue:

- **Evaluación inicial** (25/10/2026) con 01_verificacion_controles.sql (PT-00 a PT-15).
- **Implementación** con 04_implementar_controles.sql y 04b_completar_separacion_funciones.sql.

- **Procedimientos de servidor**: retención y respaldo cifrado con RMAN, y cifrado de red en sqlnet.ora.
- **Pruebas funcionales** PF-01 a PF-07 con 03_pruebas_funcionales.sql y PF-08 en RMAN.
- **Revisión de privilegios** con 05_cerrar_revision_privilegios.sql y un acta de decisiones.
- **Evaluación final** (27/10/2026) con el mismo script de verificación de la evaluación inicial.

4. Descripción del artefacto

El artefacto es una página web publicada que reúne todo el análisis y funciona como herramienta de evaluación. Sus evaluaciones se guardan en una base de datos compartida, de modo que el profesor y la estudiante ven la misma información desde cualquier navegador. Contiene una introducción, un resumen y seis secciones:

Sección	Contenido
1. Riesgos	Los cinco riesgos R-CONF con escenario, vulnerabilidad, valoración I×P y tareas relacionadas.
2. Tareas DBA	Doce tareas (T-01 a T-12) con su criticidad y los comandos y vistas que las verifican.
3. Controles ISO	Mapeo de cada tarea a controles del Anexo A, con implementación sugerida y evidencia observable.
4. Observables	Quince controles observables por un auditor externo (CO-01 a CO-15), cada uno con su prueba PT.
5. Matriz	Registro de evaluaciones: Tarea, Riesgo, Control, Criterio 0-4, Evidencia y Estado, con archivos adjuntos.
6. Evidencia	Resultados de las evaluaciones: RC, semáforo, evolución en el tiempo, mapa de calor y visor de archivos.

Tabla 2. Componentes del artefacto.

Los scripts del proyecto acompañan el artefacto: 00 y 00b crean la cuenta del auditor y le dan permisos de lectura; 01 ejecuta las pruebas de verificación; 02 crea datos de prueba; 03 ejecuta las pruebas funcionales; 04 y 04b implementan los controles; 05 cierra la revisión de privilegios, y 06 documenta los procedimientos de servidor.

5. Resultados

5.1 Evaluaciones simuladas: Tres Patitos

A solicitud del curso se simularon dos evaluaciones de la empresa ficticia Tres Patitos sobre XEPDB1, para mostrar cómo se registra y compara una evaluación en el tiempo. Ningún dato de esta sección proviene de una ejecución real.

Evaluación	Fecha	RC	Semáforo	Principales pendientes
Tres Patitos · 1.ª	23/10/2026	53,5 %	Amarillo	Separación de funciones, cifrado de red, revisión de privilegios, VPD parcial.
Tres Patitos · 2.ª	23/11/2026	76,4 %	Verde	Separación de funciones (A5.33), cifrado de red (A8.20) y revisión de privilegios (A5.18).

Tabla 3. Resultados de las evaluaciones simuladas.

5.2 Evaluaciones reales: Laboratorio UNA · XEPDB1

La evaluación inicial mostró una base con la configuración por defecto: la cuenta de ejemplo HR abierta, con su contraseña original y el rol DBA; ninguna política de VPD ni de redacción; perfil de contraseñas sin función de verificación; conexiones sin cifrado obligatorio, y sin respaldos cifrados. Después de la implementación, la evaluación final encontró doce de los quince controles del RC en nivel 3.

Control	ISO	Nombre	25/10	27/10	Estado final
M-01	A5.12	Clasificación de la información	2	2	Parcial
M-02	A5.15	Control de acceso	1	**3**	Cumple
M-03	A5.16	Gestión de identidades	1	**3**	Cumple
M-04	A5.17	Información de autenticación	1	**3**	Cumple
M-05	A5.18	Derechos de acceso	0	**3**	Cumple
M-06	A5.33*	Separación de funciones y registros	1	**3**	Cumple
M-07	A8.2	Derechos de acceso privilegiado	1	**3**	Cumple
M-08	A8.3	Restricción de acceso a la información	0	**3**	Cumple
M-09	A8.5	Autenticación segura	1	**3**	Cumple
M-10	A8.10	Eliminación de información	2	**3**	Cumple
M-11	A8.11	Enmascaramiento de datos	0	**3**	Cumple
M-12	A8.12	Prevención de fuga de datos	0	**1**	No cumple
M-13	A8.13	Respaldo de la información	1	**2**	Parcial
M-14	A8.15	Registro (logging)	2	**3**	Cumple
M-15	A8.20	Seguridad de redes	0	**3**	Cumple
M-16	A8.8	Vulnerabilidades técnicas (fuera del RC)	0	0	No cumple
RC		Riesgo de confidencialidad controlado	8,8 %	**86,6 %**	Rojo → Verde

Tabla 4. Criterio de madurez por control en las evaluaciones reales. En negrita, los niveles que cambiaron.
*El control M-06 verifica la separación de funciones entre la administración y la auditoría.

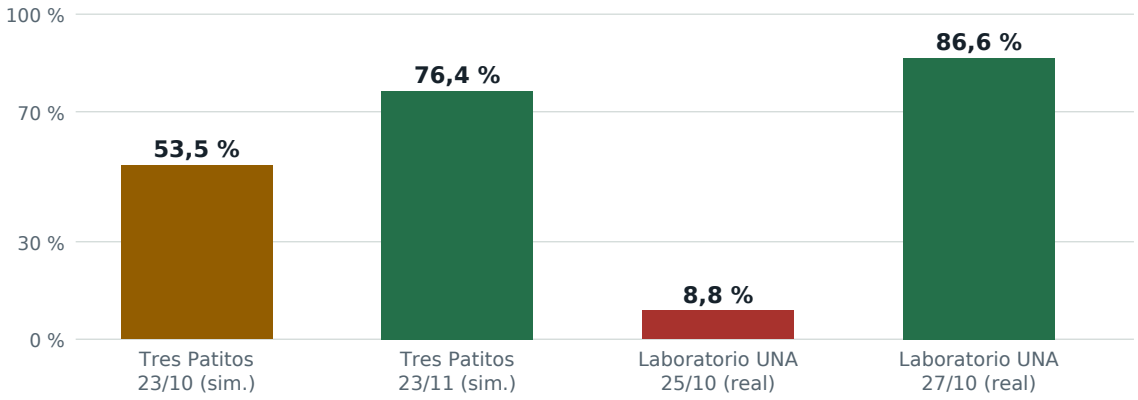


Figura 1. RC de las cuatro evaluaciones registradas en el artefacto. Rojo: 0-30 %; amarillo: 30-70 %; verde: 70-100 %.

5.3 Pruebas funcionales

Las pruebas funcionales comprueban que cada control impide lo que debe impedir, no solo que está configurado.

Prueba	Control	Resultado obtenido
PF-01	A8.5	Tras tres contraseñas incorrectas la cuenta quedó bloqueada (ORA-28000, LOCKED(TIMED)).
PF-02	A5.17	La contraseña débil abc123 fue rechazada (ORA-28003).
PF-03	A5.15	Sin el rol ROL_RRHH la tabla no es visible (ORA-00942); con el rol, la consulta funciona.
PF-04	A8.11	La cédula se muestra como *-****-1111 y el salario como 0.
PF-05	A8.3	Cada usuario ve solo las filas de su departamento (TI o CONTA).
PF-06	A8.15	La auditoría registró cada lectura de RRHH.EMPLEADOS con usuario, acción y hora.
PF-07	A5.33	El DBA operativo no puede crear ni desactivar políticas de auditoría (ORA-01031); la responsable de auditoría sí.
PF-08	A8.13	RESTORE DATABASE VALIDATE leyó y descifró el respaldo del 25/10 sin errores.

Tabla 5. Pruebas funcionales en Oracle 21c XE (27/10/2026). Las ocho pruebas pasaron.

5.4 Revisión de privilegios

La captura CAP_REVISION registró los privilegios usados entre el 25 y el 27 de octubre. Ninguna cuenta propia tenía privilegios sin usar sobre los esquemas de negocio, salvo SYSTEM, que había recibido ROL_RRHH de forma automática al crear el rol; ese privilegio se revocó. Los privilegios administrativos de ADMIN_BD y AUDITOR_SEG se justificaron por su función, y los de TLD_USER, cuenta de otro curso, se documentaron como excepción con su riesgo residual y una condición de revisión. Las decisiones quedaron en un acta firmada.

6. Problemas encontrados y lecciones aprendidas

La ejecución real mostró situaciones que no aparecen en una simulación. Documentarlas es parte de la fase Actuar del ciclo PHVA:

- **El control rechazó al propio implementador.** Las primeras contraseñas de ADMIN_BD y AUDITOR_SEG fueron rechazadas por la función de verificación (ORA-28003). Fue la primera evidencia de que el control A8.5 funcionaba.
- **Una prueba mal diseñada.** En la primera versión de PF-07, el DBA operativo falló por no ver la tabla (ORA-00942) y no por falta del privilegio de auditoría. La prueba se rediseñó para que el único motivo posible del fallo fuera el privilegio (ORA-01031).
- **Bloqueo de una cuenta administrativa.** Varios intentos con una contraseña mal escrita bloquearon SYSTEM, que se desbloqueó con SYSDBA. Muestra que el bloqueo por intentos fallidos también protege a las cuentas privilegiadas.
- **Cambios de configuración que requieren reinicio.** En Windows, el cifrado de red de sqlnet.ora solo se activó después de reiniciar el servicio de la base, no solo el listener.
- **Herramientas y evidencia.** SQL Developer perdió el archivo de salida en scripts con muchos cambios de conexión; las pruebas se ejecutaron en SQL*Plus. Algunos reportes generaron miles de filas y se resumieron para que la evidencia fuera revisable.

7. Pendientes y recomendaciones

Control	Hallazgo	Recomendación
A8.12 (M-12)	Los tablespaces no están cifrados y no hay keystore.	Configurar TDE con un keystore protegido y cifrar los tablespaces con datos sensibles.
A8.13 (M-13)	Quedan 16 piezas de respaldo antiguas sin cifrar y no hay respaldo diario.	Programar respaldos diarios cifrados y retirar las piezas sin cifrar cuando venzan.
A5.12 (M-01)	Las columnas sensibles están etiquetadas, pero no hay inventario aprobado.	Documentar y aprobar el inventario de datos sensibles y revisarlo con cada cambio de esquema.
A8.8 (M-16)	La base sigue en la versión 21.3 sin parches de seguridad.	Establecer un proceso trimestral de revisión y aplicación de parches.
Nivel 4	Ningún control tiene evidencia de revisión periódica.	Repetir la evaluación cada trimestre y registrar cada una en el artefacto.

Tabla 6. Pendientes de la evaluación final.

8. Conclusiones

- Analizar la confidencialidad desde las tareas del DBA permitió ligar cada control de ISO/IEC 27001:2022 con una acción concreta en Oracle y con una evidencia que un auditor externo puede comprobar con una consulta.

- La implementación elevó el RC real de 8,8 % (rojo) a 86,6 % (verde). La mejora se concentró en control de acceso, privilegios, enmascaramiento, VPD, auditoría y cifrado de red, que eran los controles de mayor peso.
- Las pruebas funcionales fueron indispensables: una configuración presente no garantiza que el control funcione, como mostró el rediseño de PF-07.
- Llegar al nivel 4 no depende de más tecnología, sino de constancia: revisiones periódicas de privilegios, de respaldos y de la auditoría, registradas como evaluaciones sucesivas.
- Los controles implementados son medidas técnicas y organizativas que ayudan a demostrar el cumplimiento del artículo 10 de la Ley 8968 sobre la seguridad de los datos personales.

9. Uso de inteligencia artificial

En este proyecto se utilizó un asistente de inteligencia artificial (Claude, de Anthropic) como apoyo para estructurar el análisis, redactar borradores, construir el artefacto web y escribir los scripts SQL. La estudiante revisó cada resultado, ejecutó personalmente todos los scripts en su instalación de Oracle, interpretó la evidencia y tomó las decisiones de evaluación, como los criterios de madurez y las excepciones del acta de privilegios. El detalle de cada uso y su validación se presenta en la tabla de uso de IA y en la declaración jurada que acompañan este informe.

Referencias

Asamblea Legislativa de la República de Costa Rica. (2011). *Ley n.° 8968: Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales*. La Gaceta n.° 170, 5 de setiembre de 2011. https://www.archivonacional.go.cr/web/normativa/ley8968.docx

International Organization for Standardization y International Electrotechnical Commission. (2022a). *ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. ISO.

International Organization for Standardization y International Electrotechnical Commission. (2022b). *ISO/IEC 27002:2022. Information security, cybersecurity and privacy protection — Information security controls*. ISO.

Kent, K. y Souppaya, M. (2006). *Guide to computer security log management* (NIST Special Publication 800-92). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-92

Oracle. (2021a). *Oracle Database Reference, 21c*. https://docs.oracle.com/en/database/oracle/oracle-database/21/refrn/

Oracle. (2021b). *Oracle Database Advanced Security Guide, 21c*. https://docs.oracle.com/en/database/oracle/oracle-database/21/asoag/

Oracle. (2021c). *Oracle Database Security Guide, 21c*. https://docs.oracle.com/en/database/oracle/oracle-database/21/dbseg/

Oracle. (2021d). *Oracle Database Backup and Recovery User's Guide, 21c*. https://docs.oracle.com/en/database/oracle/oracle-database/21/bradv/

Poder Ejecutivo de la República de Costa Rica. (2013). *Decreto Ejecutivo n.° 37554-JP: Reglamento a la Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales*. https://www.archivonacional.go.cr/web/normativa/reglamento37554.docx

Rescorla, E. (2018). *The Transport Layer Security (TLS) Protocol Version 1.3* (RFC 8446). Internet Engineering Task Force. https://doi.org/10.17487/RFC8446

Rose, S., Borchert, O., Mitchell, S. y Connelly, S. (2020). *Zero trust architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207

Saltzer, J. H. y Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE, 63*(9), 1278-1308. https://doi.org/10.1109/PROC.1975.9939

Anexo A. Archivos de evidencia

Los archivos están adjuntos a cada evaluación en el artefacto y en la carpeta *evidencias* del repositorio.

Evaluación	Archivo	Contenido
Inicial 25/10	evidencia_verificacion_inicial.txt	Pruebas PT-00 a PT-15 antes de implementar.
Inicial 25/10	evidencia_verificacion_intento1.txt	Primera ejecución, con errores de permisos de AUDITOR_EXT.
Final 27/10	evidencia_verificacion_final.txt	Pruebas PT-00 a PT-15 después de implementar.
Final 27/10	evidencia_implementacion.txt y _parte2.txt	Salida de los scripts 04 y 04b.
Final 27/10	evidencia_servidor.txt	RMAN (retención y respaldo cifrado) y sqlnet.ora (cifrado de red).
Final 27/10	evidencia_funcional.txt	Pruebas funcionales PF-01 a PF-07.
Final 27/10	evidencia_pf08.txt	Validación de la restauración del respaldo (PF-08).
Final 27/10	evidencia_revision_privilegios.txt y acta	Resultado de la captura de privilegios y decisiones firmadas.